ASSIGNMENT 6

Introduction to Network Security and Cryptography in Network Security

Cryptography and Network Security

Coverage: Network security principles, common attacks and defenses, legal and ethical responsibilities, cryptography, SSL/TLS, IPsec, PKI, digital certificates and Certificate Authorities.

Note: This document provides structured model answers to all five questions in the supplied assignment, with examples, tables and labelled process diagrams.

Q1. Network Security: Principles and Objectives

Definition: Network security is the set of policies, technologies, controls and practices used to protect network infrastructure, connected devices, applications and transmitted data against unauthorized access, misuse, alteration, disruption or destruction. Its goal is to preserve trustworthy and reliable communication.

Fundamental principles: the CIA triad and access control

- **Confidentiality:** information is disclosed only to authorized people or systems. Encryption, access controls and data classification help protect confidentiality. Example: TLS encrypts data sent to a banking website.
- **Integrity:** data remains accurate and unaltered except through authorized changes. Cryptographic hashes, message authentication codes, digital signatures and controlled change processes help detect or prevent unauthorized modification.
- **Availability:** systems and services remain accessible when needed. Redundancy, backups, patching, capacity planning, monitoring and DDoS mitigation support availability.
- **Authentication:** verifies the identity of a user, device or service. Passwords, multifactor authentication, certificates and security keys can support authentication.
- **Authorization:** determines what an authenticated identity is allowed to do. Role-based access control, least privilege and access policies enforce authorization. Authentication answers “Who are you?”; authorization answers “What are you allowed to do?”

Additional principles

- Least privilege: give each user or service only the permissions needed for its task.
- Defense in depth: use multiple complementary controls, so one failed control does not expose the whole system.
- Accountability and auditing: log relevant events, protect logs and review them to investigate incidents.
- Non-repudiation: digital signatures and reliable records may provide evidence of actions, subject to identity and key-management controls.

Example security flow

Step	Security function	Example
1	Authentication	Employee signs in using MFA.
2	Authorization	Access policy permits the employee to view only assigned files.
3	Confidentiality and integrity	TLS protects data in transit; integrity checks detect tampering.
4	Availability	Redundant systems and backups support recovery from failures.

Q2. Threat Landscape: Network Attacks, Vulnerabilities and Prevention

Threat landscape refers to the range of attackers, techniques, weaknesses and conditions that can compromise network systems. Threat actors may include cybercriminals, insiders, hacktivists, competitors or state-sponsored groups. A vulnerability is a weakness; a threat is something that may exploit it; risk combines likelihood and impact.

Attack / vulnerability	Example	Preventive or mitigating measures
Phishing / social engineering	A fake login page steals a user password.	Awareness training, MFA, phishing-resistant security keys, email filtering and reporting.
Malware / ransomware	Malicious software steals data or encrypts files.	Patch systems, endpoint protection, least privilege, backups and application controls.
DoS / DDoS	Traffic floods make a public service unavailable.	DDoS protection, rate limiting, traffic filtering, redundancy and incident response.
Man-in-the-middle (MITM)	An attacker intercepts or alters traffic on an unsafe network.	Use authenticated TLS, validate certificates, avoid insecure protocols and protect Wi-Fi.
Password / credential attacks	Password spraying or credential stuffing targets accounts.	MFA, unique passwords, rate limiting, breached-password checks and monitoring.

Attack / vulnerability	Example	Preventive or mitigating measures
Unpatched software / misconfiguration	An exposed service has a known flaw or default password.	Asset inventory, timely patching, secure configuration, vulnerability scanning and change control.
Injection / application flaws	Untrusted input manipulates a server-side query.	Input validation, parameterized queries, secure development and testing.
Insider misuse / privilege abuse	An authorized account accesses or exports data improperly.	Least privilege, separation of duties, logging, alerts and periodic access reviews.
Spoofing / DNS attacks	An attacker impersonates a host or redirects a domain lookup.	Secure DNS practices, certificate validation, network filtering and monitoring.

General risk-reduction approach

- Maintain an inventory of devices, applications, accounts and exposed services.
- Apply security updates, disable unnecessary services and replace default credentials.
- Use segmentation, firewalls, secure remote access, MFA and least-privilege permissions.
- Encrypt sensitive data in transit and at rest; maintain tested offline or immutable backups.
- Monitor logs and network traffic, test incident-response plans, and report suspicious activity promptly.

Important: no single tool prevents every attack. Security requires layered controls, regular review and response planning.

Q3. Legal and Ethical Considerations in Network Security

1. Data privacy

Organizations should collect only data needed for a defined purpose, explain how it will be used, protect it against unauthorized access and retain it only as long as justified. Access to personal data should be limited and securely logged. Data breaches should be handled under applicable legal and organizational requirements.

2. Responsible and authorized security testing

Penetration testing, vulnerability scanning and red-team exercises must have explicit written authorization and a defined scope. The agreement should identify permitted systems, dates, methods, limits, contacts and reporting rules. Testers should avoid unnecessary disruption, use safe test data where possible, protect discovered information and promptly report critical findings. Testing systems without permission may violate laws and cause harm even if the intention is to improve security.

3. Authorized access and ethical conduct

- Access only systems and data for which permission has been granted.
- Do not bypass access controls, copy private data, plant backdoors or use discovered credentials beyond the authorized scope.
- Preserve evidence carefully, maintain confidentiality, document actions and disclose findings through agreed channels.
- Follow responsible disclosure practices: give the affected organization a reasonable opportunity to investigate and remediate before public disclosure, unless a different lawful process applies.

4. Compliance with applicable law

Legal duties vary by country, sector, contract and type of data. In India, relevant frameworks may include the Information Technology Act, 2000 and applicable rules, the Digital Personal Data Protection Act, 2023 and rules/commencement provisions in force at the relevant time, sectoral requirements, and contractual obligations. Organizations should verify the currently applicable provisions with qualified legal or compliance professionals rather than assume that one rule applies to every situation.

5. Ethics and professional responsibility

- Use security skills to protect users and systems, not to exploit them.
- Be honest about findings, methods and limitations; do not exaggerate vulnerabilities.
- Minimize harm, respect privacy, avoid conflicts of interest and keep sensitive findings confidential.

• Keep skills current and follow professional codes of conduct and organizational policy.

Example: a student may scan a university network only if the university has explicitly authorized that scan and defined its scope. A public IP address being reachable does not imply permission to test it.

Q4. Role of Cryptography, SSL/TLS and IPsec

Role of cryptography in network security

Cryptography supports confidentiality through encryption; integrity through cryptographic hashes and message authentication; authentication through certificates and digital signatures; and key establishment through key-agreement protocols. Cryptography is effective only when algorithms, parameters, keys, implementations and certificate validation are handled correctly.

SSL/TLS

SSL (Secure Sockets Layer) is obsolete and should not be used. TLS (Transport Layer Security) is its modern successor and protects application traffic such as HTTPS. In a typical TLS connection, the client and server negotiate protocol parameters, authenticate the server using a certificate (and sometimes authenticate the client), perform a key exchange, derive session traffic keys, and then protect application records using authenticated encryption. Modern deployments generally use TLS 1.2 or TLS 1.3 with secure configurations.

TLS stage	What happens	Security result
Handshake	Negotiate version and algorithms; exchange key material.	Agree on parameters and establish shared secrets.
Authentication	Validate certificate chain, server name and signature; optionally authenticate client.	Helps prevent impersonation and man-in-the-middle attacks.
Key derivation	Derive separate session traffic keys from shared secret and handshake data.	Limits direct exposure of the key-exchange secret.
Protected records	Encrypt and authenticate application data with an AEAD algorithm.	Confidentiality and tamper detection in transit.

IPsec

IPsec is a suite of protocols that protects IP packets at the network layer. It is widely used in site-to-site and remote-access VPNs. Its main protection protocols are Authentication Header (AH), which provides integrity and origin authentication but not encryption, and Encapsulating Security Payload (ESP), which can provide confidentiality, integrity and data-origin authentication. ESP is the commonly used option for VPN traffic.

- **Transport mode:** protects the IP payload while retaining the original IP header; commonly used for host-to-host communication.
- **Tunnel mode:** encapsulates and protects the whole original IP packet inside a new packet; commonly used for VPN gateways and site-to-site VPNs.

Internet Key Exchange (IKE/IKEv2) negotiates security associations, authenticates peers and establishes key material for IPsec. Correct configuration, strong algorithms, secure credentials/certificates and regular updates are important.

Feature	TLS	IPsec
Layer / scope	Usually protects a particular application connection or transport stream.	Protects IP packets at the network layer.
Typical use	HTTPS, secure APIs, email and other application protocols.	Site-to-site VPNs and remote-access VPNs.
Deployment	Often configured by the application/server.	Often configured in operating systems, endpoints or network gateways.
Trust / key setup	Certificates and handshake key exchange are common.	Security associations commonly negotiated using IKE.

Summary: TLS protects many application connections; IPsec can protect traffic at the IP layer across a network or VPN. Both rely on cryptographic algorithms, authenticated key establishment and correct configuration.

Q5. Public Key Infrastructure (PKI): Components and Working

Definition: Public Key Infrastructure (PKI) is the collection of roles, policies, procedures, hardware and software used to create, distribute, validate, renew and revoke digital certificates and their associated public keys. PKI helps users determine whether a public key should be trusted as belonging to a particular identity.

Main components

- **Certificate Authority (CA):** verifies certificate requests according to its policy and digitally signs issued certificates.
- **Registration Authority (RA):** may perform identity checks and approve requests on behalf of a CA.
- **Digital certificate:** a structured, digitally signed statement binding an identity or subject to a public key, with issuer, validity period, serial number, key usage and other fields.
- **Public/private key pair:** the public key can be distributed; the private key must be securely controlled by its owner.
- **Certificate repository:** a location or directory from which certificates and related information can be retrieved.
- **Revocation/status mechanisms:** Certificate Revocation Lists (CRLs) and Online Certificate Status Protocol (OCSP) can communicate certificate status, depending on the ecosystem.

How PKI works

Step	Action
1. Key generation	The subject generates a key pair and protects the private key.
2. Certificate request	The subject sends a Certificate Signing Request (CSR) or equivalent request to the CA/RA.
3. Identity validation	The CA/RA verifies identity or domain control according to certificate policy.
4. Certificate issuance	The CA signs and issues a certificate binding the validated identity to the public key.
5. Certificate distribution	The certificate is provided to peers or published in a repository.
6. Validation	A client checks the certificate signature chain, trusted root, name, validity, key usage and applicable revocation/status information.
7. Use and renewal/revocation	The validated key supports authentication or signature verification; certificates are renewed or revoked when needed.

Role of digital certificates and CAs

A certificate is not simply a public key; it contains identity information and is signed by an issuer that the relying party may trust. The CA's signature lets a client verify that the certificate was issued under the CA's authority and has not been altered. The client must still check that the certificate is appropriate for the intended service and that the chain leads to a trusted root. If an attacker substitutes a public key without a valid certificate for the intended identity, certificate validation should reject it.

Example: HTTPS website

When a browser connects to a secure website, the server presents its certificate. The browser checks the domain name, validity, certificate chain and applicable status. If checks pass, the TLS handshake authenticates the server and establishes session keys. The browser then uses the secure connection to protect data in transit.

PKI security practices

- Keep CA private keys in strongly protected systems and restrict issuance privileges.
- Use approved algorithms and key sizes, protect end-entity private keys, and monitor certificate expiry.
- Validate certificate names and chains correctly; do not ignore certificate warnings.
- Revoke or replace compromised keys/certificates and maintain clear issuance and renewal procedures.
- Use automation and monitoring to reduce expired certificates and configuration errors.

Conclusion: PKI creates a scalable trust framework for public keys. Certificates and CAs support authentication for TLS, digital signatures and other secure network services, but trust depends on sound identity checks, key protection, certificate validation and lifecycle management.

References for further reading

1. NIST SP 800-52 Rev. 2, *Guidelines for the Selection, Configuration, and Use of TLS Implementations*.
2. NIST SP 800-77 Rev. 1, *Guide to IPsec VPNs*.
3. RFC 8446, *The Transport Layer Security (TLS) Protocol Version 1.3*.
4. RFC 4301, *Security Architecture for the Internet Protocol*.
5. RFC 5280, *Internet X.509 Public Key Infrastructure Certificate and CRL Profile*.